AREM · UNIVERSIDAD DE LA SABANA · MÓDULO 06

Seguridad Arquitectónica y análisis STRIDE

Un manual táctico para evaluar amenazas en el diseño de sistemas

Objetivo: comprender los principios de seguridad en arquitecturas empresariales y aplicar el modelo STRIDE para identificar amenazas en sistemas reales.

Profesor: Ing. César Augusto Vega Fernández

01 · OBJETIVO

Qué se lleva del módulo

La seguridad como decisión de diseño, no como capa añadida

01 Distinguir

Separar los principios de seguridad arquitectónica de los controles de implementación.

02 Aplicar

Recorrer las seis categorías de STRIDE sobre un flujo concreto de un sistema real.

03 Controlar

Asociar a cada amenaza identificada un control de mitigación concreto y verificable.

04 Anticipar

Reconocer las amenazas propias de los sistemas con IA, que STRIDE por sí solo no cubre.

ENTREGABLE · TALLER 5

- Un flujo crítico del sistema del cliente, modelado con sus límites de confianza
- Tabla STRIDE completa: las seis categorías evaluadas para ese flujo
- Un control de mitigación por amenaza aplicable
- Nivel de riesgo justificado para cada hallazgo

¿Qué es la seguridad arquitectónica?

Parte fundamental de una arquitectura resiliente y confiable

CAPA 1

Prevenir

Diseñar el sistema con mecanismos que bloqueen los vectores de entrada antes de que se usen.

Autenticación fuerte, segmentación de red, validación de entrada.

CAPA 2

Detectar

Instrumentar el sistema para reconocer anomalías operativas mientras ocurren.

Registros de auditoría, alertas, monitoreo de comportamiento.

CAPA 3

Mitigar

Contener el daño cuando la amenaza ya atravesó el perímetro.

Aislamiento, revocación de sesiones, restauración desde respaldo.

El error más común: invertir todo en la capa 1 y nada en las otras dos. Un sistema que solo previene no sabe cuándo lo atacaron, y cuando lo descubre no tiene con qué responder. Las tres capas se diseñan juntas.

Los cinco pilares de la confianza

Lo que un sistema seguro debe garantizar, antes de hablar de amenazas

01 Confidencialidad

Solo quien debe ver la información la ve.

Cifrado en tránsito y en reposo

02 Integridad

La información no se altera sin autorización ni sin dejar rastro.

Firmas digitales, hashing

03 Disponibilidad

El sistema responde cuando se le necesita.

Redundancia, rate limiting

04 Autenticación

El sistema sabe quién es cada quien.

MFA y, cada vez más, passkeys

05 Autorización

Cada quien puede hacer únicamente lo que le corresponde.

Control de acceso por roles, mínimo privilegio

CADA PILAR TIENE SU LETRA

Los cinco pilares no son una lista aparte: cada categoría de STRIDE es exactamente la violación de uno de ellos. Por eso el modelo es completo y no arbitrario.

Anatomía de STRIDE

Seis categorías, una por cada pilar que se puede violar

S	T	R	I	D	E
Suplantación	**Manipulación**	**Repudio**	**Divulgación**	**Denegación**	**Elevación**
`Spoofing`	`Tampering`	`Repudiation`	`Info disclosure`	`Denial of service`	`Elevation of privilege`
Falsificar la identidad de un usuario o un sistema.	Modificar datos en tránsito o en reposo sin autorización.	Negar haber ejecutado una acción, sin que se pueda probar.	Exponer información a quien no debería verla.	Interrumpir el servicio para los usuarios legítimos.	Obtener permisos superiores a los concedidos.
viola Autenticación	*viola Integridad*	*viola Trazabilidad*	*viola Confidencialidad*	*viola Disponibilidad*	*viola Autorización*

Cómo se aplica STRIDE

Tres pasos, en este orden, sobre un flujo a la vez

PASO 1

Enfocar

Seleccionar un flujo o componente crítico del sistema. No se modela todo el sistema de una vez: se elige el flujo donde más duele un fallo.

En EduKit: el flujo de carga de notas.

PASO 2

Atacar

Recorrer las seis categorías de STRIDE por cada punto de entrada o interacción del flujo. La pregunta es siempre: ¿cómo rompería yo esto?

¿Puede un estudiante hacerse pasar por docente?

PASO 3

Sistematizar

Documentar impacto, control de mitigación y nivel de riesgo de cada hallazgo, en una tabla que se pueda revisar después.

Tabla de amenazas y controles del entregable.

El embudo se estrecha a propósito: modelar amenazas de todo el sistema a la vez produce una lista larga que nadie usa. Un flujo bien analizado vale más que veinte enunciados genéricos.

Matriz de amenazas y controles

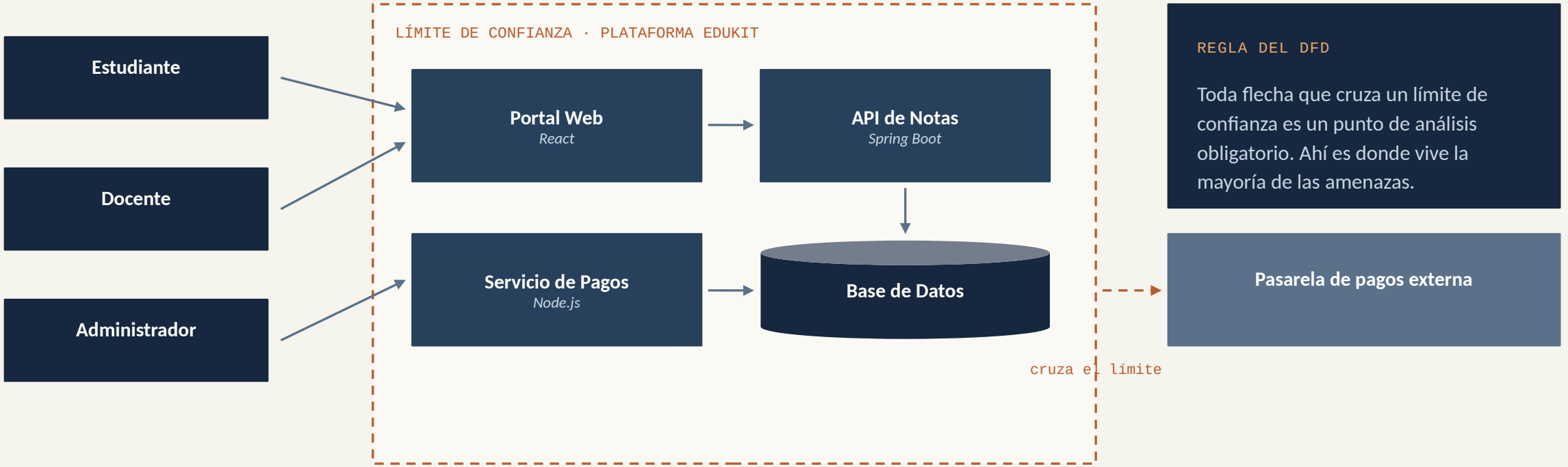
Las seis categorías, cada una con su respuesta de diseño

	AMENAZA	CONTROL DE DISEÑO
S	**Suplantación**	→ Autenticación multifactor; passkeys; identidad verificada entre servicios
T	**Manipulación**	→ Firmas digitales, hashing, integridad verificada en cada transferencia
R	**Repudio**	→ Registros de auditoría inmutables, sellado de tiempo, firma de transacciones
I	**Divulgación**	→ Cifrado en tránsito y en reposo; enmascaramiento de datos sensibles
D	**Denegación de servicio**	→ Rate limiting, WAF, autoescalado, degradación controlada
E	**Elevación de privilegios**	→ Mínimo privilegio, control de acceso por roles, revisión periódica de permisos

Un control por amenaza no basta si el control vive en otra capa: verificar siempre dónde se aplica y quién lo opera.

Escenario táctico: plataforma EduKit

Diagrama de flujo de datos con sus límites de confianza



REGLA DEL DFD

Toda flecha que cruza un límite de confianza es un punto de análisis obligatorio. Ahí es donde vive la mayoría de las amenazas.

Del Módulo 4 al Módulo 6: este diagrama es el de contenedores del Taller 3 con una sola cosa añadida: el límite de confianza dibujado. No hay que empezar de cero; hay que tomar el diagrama que ya existe y trazarle la frontera.

STRIDE sobre el flujo «subir notas»

Un flujo, seis preguntas, seis respuestas

	PREGUNTA	ESCENARIO	CONTROL	RIESGO
S	**¿Puede un estudiante hacerse pasar por docente?**	Sesión robada o credencial compartida	MFA para el rol docente; sesiones cortas	Alto
T	**¿Se puede alterar una nota en tránsito?**	Petición interceptada entre portal y API	HTTPS obligatorio; validación en servidor, no solo en el cliente	Alto
R	**¿Puede un docente negar que cambió una nota?**	Sin registro de auditoría no hay cómo probarlo	Bitácora inmutable con usuario, valor anterior y marca de tiempo	Alto
I	**¿Puede un estudiante ver notas ajenas?**	Consulta por identificador sin verificar propiedad	Autorización a nivel de registro, no solo de pantalla	Medio
D	**¿Se puede tumbar el sistema en semana de cierre?**	Pico de carga concentrado en pocas horas	Autoescalado y límite de peticiones por usuario	Medio
E	**¿Puede un monitor obtener permisos de docente?**	Rol mal configurado o permisos heredados	Mínimo privilegio y revisión de roles cada periodo	Alto

Ninguna de las seis amenazas requiere un atacante sofisticado: todas se explotan con un navegador y curiosidad.

09 · PRINCIPIO ACTUAL

Zero Trust: el perímetro ya no existe

Nunca confiar, siempre verificar

El modelo antiguo asumía que lo de adentro de la red era confiable. Zero Trust elimina ese supuesto: cada petición se verifica, venga de donde venga.

1 **Identidad fuerte para todo**
Personas, servicios y agentes automatizados tienen identidad propia y verificable.

2 **Mínimo privilegio**
Cada identidad recibe solo los permisos que necesita, y por el tiempo que los necesita.

3 **Credenciales de vida corta**
Tokens temporales en vez de llaves estáticas que llevan años sin rotarse.

4 **Verificación continua**
No basta con autenticar al entrar: el comportamiento se monitorea durante toda la sesión.

POR QUÉ VOLVIÓ A IMPORTAR

Con agentes automatizados ejecutando tareas de negocio, la pregunta deja de ser quién entra a la red y pasa a ser qué puede hacer cada identidad. Un agente sin rol, sin permisos acotados y sin monitoreo es un usuario privilegiado sin supervisor.

PREGUNTA PARA EL CLIENTE

¿Cuántas cuentas de servicio tiene el sistema, quién las creó, qué permisos tienen y cuándo se rotaron sus credenciales por última vez? En la mayoría de las organizaciones nadie sabe responder, y esa es exactamente la brecha.

La tríada letal

Tres condiciones que, juntas, hacen explotable a cualquier agente de IA

Acceso a datos privados

El agente puede leer información sensible: historia clínica, nómina, contratos.

+

Exposición a contenido no confiable

El agente procesa texto que viene de afuera: correos, documentos, páginas web.

+

Capacidad de comunicar hacia afuera

El agente puede enviar correos, llamar APIs o escribir en sistemas externos.

EL RESULTADO

Un atacante esconde instrucciones dentro del contenido que el agente va a leer. El agente las obedece como si vinieran del usuario, consulta los datos privados y los envía hacia afuera. Nadie explotó una vulnerabilidad de código: se usó el sistema exactamente como fue diseñado.

LA MITIGACIÓN

Romper la tríada. Basta con quitar una de las tres condiciones: limitar los datos que el agente alcanza, aislar el contenido no confiable o restringir a dónde puede escribir.

MITRE ATLAS: STRIDE no alcanza para la IA

Base de conocimiento de tácticas adversarias contra sistemas de IA

STRIDE fue diseñado para sistemas deterministas. Un componente que responde distinto ante la misma entrada abre categorías de amenaza que el modelo no contempla.

Inyección de instrucciones

Contenido que el modelo interpreta como orden en vez de como dato.

Envenenamiento de datos

Manipular el conjunto de entrenamiento o la base de conocimiento.

Extracción del modelo

Reconstruir el modelo o sus datos a partir de consultas sistemáticas.

Evasión

Entradas diseñadas para que el modelo clasifique mal deliberadamente.

QUÉ ES

Una base de conocimiento de tácticas y técnicas adversarias contra sistemas de IA y aprendizaje automático. Es más acotada que MITRE ATT&CK y está diseñada para complementarla, no para reemplazarla.

PARA QUÉ SIRVE EN CLASE

Da vocabulario compartido. Sin él, los riesgos de IA se discuten con adjetivos y terminan como una casilla marcada en un checklist.

Regla práctica: si el sistema del cliente incluye un componente de IA, la tabla STRIDE se complementa con ATLAS. Si no, STRIDE basta.

Cuatro decisiones que se toman temprano

Y que cuestan mucho más si se toman tarde

01 Security by design

La seguridad se implementa desde el inicio, no se agrega al final del proyecto.

Cuesta poco al diseñar y muchísimo al reparar.

02 Defensa en profundidad

Varias capas de control, para que fallar una no signifique quedar expuesto.

Ningún control único es suficiente.

03 Segmentación

Separación estricta de redes, entornos y roles de usuario.

Limita hasta dónde llega un atacante que ya entró.

04 Observabilidad

Auditoría constante y trazabilidad de los eventos críticos del sistema.

Sin registros no hay forma de saber qué pasó.

El arsenal del arquitecto

Todas gratuitas o con licencia libre para uso académico

OWASP Threat Dragon

GRATUITO · WEB Y ESCRITORIO

Herramienta de modelado de amenazas respaldada por OWASP. Se dibuja el diagrama de flujo de datos y se anotan las amenazas sobre él.

Recomendada para el taller

Microsoft Threat Modeling Tool

GRATUITO · WINDOWS

El estándar histórico de STRIDE. Genera automáticamente amenazas candidatas a partir del diagrama.

Útil si el equipo trabaja en Windows

Plantilla STRIDE en hoja de cálculo

GRATUITO

La tabla de seis filas del ejemplo trabajado. Sin instalación y suficiente para el entregable.

La opción segura contrarreloj

C4 con anotación de seguridad

GRATUITO · DRAW.IO

El diagrama de contenedores del Taller 3 con los límites de confianza dibujados encima.

El punto de partida de todo

La herramienta no se califica. Se califica que la tabla tenga las seis categorías y que cada control sea verificable.

Modelado de amenazas en clase · 40 minutos

En equipos, sobre el sistema del cliente real

10 min

Dibujar la frontera

Tomen su diagrama de contenedores del Taller 3 y tracen encima los límites de confianza. Marquen con color toda flecha que cruce uno.

15 min

Atacar el flujo

Elijan el flujo más crítico y recorran las seis categorías. Escriban el escenario, no solo el nombre de la amenaza.

10 min

Asignar controles

Un control por amenaza aplicable, y el nivel de riesgo con su justificación.

5 min

Ataque cruzado

Intercambien con otro equipo: ellos deben encontrar una amenaza que ustedes no vieron.

ERRORES QUE VAMOS A BUSCAR

- Tabla con cuatro categorías en vez de seis
- Amenazas sin escenario: solo el nombre
- Controles genéricos tipo «usar buenas prácticas»
- Límites de confianza no dibujados

PARA LLEVARSE

Seguridad arquitectónica en cuatro ideas

01 **La seguridad se diseña**

No es una capa que se agrega al final; se decide cuando se dibuja el sistema.

02 **Seis letras, no cuatro**

Repudio y elevación de privilegios son las que más se olvidan y las que más aparecen.

03 **El riesgo está en la frontera**

Toda flecha que cruza un límite de confianza es un punto de análisis obligatorio.

04 **La IA cambió el mapa**

STRIDE sigue vigente, pero los sistemas con IA necesitan además ATLAS y la tríada letal.

Próximo paso: Taller 5 · modelado de amenazas del sistema del cliente, con la tabla STRIDE completa.

LECTURAS RECOMENDADAS

OWASP Threat Modeling Cheat Sheet

STRIDE per Element — Microsoft

MITRE ATLAS — atlas.mitre.org

ISO/IEC 27001 — fundamentos

NIST SP 800-207 — Zero Trust Architecture